

PGR Platform

Make-It-Real Plan

Fixing every workaround from PGR_Platform_Critical_Gaps.pdf. One entry per gap: what the workaround is, what to build, files to touch, effort, and the acceptance test that proves it real.

v1 · 2026-08-24

Effort	Meaning
S	≤ 2 engineer-days
M	3–8 engineer-days
L	2–4 engineer-weeks
XL	1–2 engineer-months

Sequenced roadmap (12 weeks to go-live-ready)

Each sprint below is a two-week fortnight and closes a named risk. Nothing here runs in parallel that cannot actually be staffed in parallel; owners should be assigned before the sprint starts.

Sprint	Weeks	Gates closed	Outcome
S0	0	Ownership + staging env stood up	Baseline for everything else
S1	1–2	#10 Deploy artefact, #3 TLS + rate limit	App runs in staging over HTTPS
S2	3–4	#4 Backup/restore drill, #11 Observability	We can see it and recover it
S3	5–6	#5 GDPR endpoints + retention, #14 person merge	legally operable
S4	7–8	#1, #2 Integration go-live (HR + Finance)	Partner systems live
S5	9–10	#6 HESA sign-off, #12 backfill, #7 S3 storage	Data correct + durable
S6	11–12	#8 Materialised 360, #9 revocation, #18 SLA	Runs at target scale + operable SLAs
S7+	13+	Medium-severity product debt (#15–#23)	Continuous product improvement

Team shape

Role	Count	Load pattern
Platform / SRE engineer	1.5	Heavy S1–S2, steady after
Backend engineer	2	Heavy S3–S5, steady after
Frontend engineer	1	Light S1–S4, heavier S6–S7
QA / release engineer	0.5	Every sprint (test drill + acceptance)
Product / IG / Registry SME	0.5	Concentrated in S3, S5

Critical work — must ship before any institution touches production

[CRIT] #1. Outbound events emit into a void

Workaround now	Outbox dispatches to OUTBOX_TARGET_URL that is unset or a scratch URL. Everything looks green but no
Real build	Register per-partner target URLs, exchange HMAC secrets, wire delivery per event type, run the 8-test go-live
Files / modules	app/modules/integration/dispatcher.py · app/modules/integration/adapters/ · app/core/config.py · docs/PGR_IL
Effort	M (5 d per partner, 3 partners → 3 wk elapsed with SME availability)
Acceptance test	1) End-to-end: approve a stipend → outbox delivers → partner ACKs → integration log shows delivered. 2) Fa

[CRIT] #2. Inbound partner webhooks: no one is sending

Workaround now	Signed webhook endpoint is real and tested, but no partner points at it. Research awards typed twice; HR-emp
Real build	Turn on HR employee.appointed first (highest volume, safest). Then Research award.created/updated. Add F
Files / modules	app/modules/integration/inbound.py · app/modules/integration/handlers/ · app/modules/person/service.py (link
Effort	M per partner (3–4 d each) · L for Finance handler (2 wk incl. reconciliation UI)
Acceptance test	1) Partner posts a real event → row upserts under the correct source_system. 2) Duplicate sourceId is idemp

[CRIT] #3. No TLS, no rate limiting, no secret store

Workaround now	App runs on HTTP on 127.0.0.1. APP_SECRET_KEY sits in .env. 5-strike lockout is the only brute-force defer
Real build	Terminate TLS at edge (nginx / ALB / Traefik). Add per-IP + per-account rate limits on /auth/* and /integration/
Files / modules	infra/ (new terraform/helm/compose) · app/core/middleware.py (rate limit) · app/core/config.py (secret provider)
Effort	M (edge + rate limits: 5 d) · S (secret migration: 2 d)
Acceptance test	1) curl over plain HTTP is refused / redirected. HSTS header set. 2) 20 failed logins in 60 s from one IP are th

[CRIT] #4. No backup, no restore drill, no rollback runbook

Workaround now	PostgreSQL runs. No PITR archive. Alembic downgrades never executed against real data. "Go back to Tues
Real build	Stand up managed backups (RDS/Flex/pgBackRest). Prove quarterly restore into a fresh instance. Test one A
Files / modules	infra/backup.tf · docs/RUNBOOK_RESTORE.md · docs/RUNBOOK_ROLLBACK.md · backend/alembic/versi
Effort	M (backup config + first drill: 5 d) · S (runbook: 2 d)
Acceptance test	1) pg_basebackup + WAL restores a database to a chosen point within ≤ 15 min RPO. 2) alembic downgrade

[CRIT] #5. GDPR: no subject-access, no erasure, no retention

Workaround now	audit_log exists. deactivate exists. Neither satisfies a subject-access request or an erasure request. Retention
Real build	Build subject-access export walking every table with a person_id FK. Build pseudonymising erasure that prese
Files / modules	app/modules/person/gdpr.py (new) · app/modules/person/routes.py (+2 endpoints) · app/worker.py (retention
Effort	L (subject-access: 1 wk) · L (erasure incl. audit-safe: 1.5 wk) · S (retention policy: 2 d, mostly SME time)
Acceptance test	1) POST /persons/{id}/export produces a portable file with every row referencing that person, verified against a

[CRIT] #6. HESA statutory profile is illustrative, not a return

Workaround now	12 fields chosen to prove the engine. No HESA subject-matter review. Generate button produces a CSV that v
Real build	Sit a HESA SME in front of the mappings for a real academic year. Add missing fields (typ. 40–70), coding-fra
Files / modules	app/modules/exports/hesa_profile_2026.json (new) · app/modules/exports/validators.py · app/modules/export
Effort	XL (SME-limited: 4–6 wk elapsed; ~10 d engineer)
Acceptance test	1) Every mandatory HESA field for the target return is present and validates. 2) A student intentionally missing

High-severity work — before go-live approval

[HIGH] #7. Object storage on local filesystem

Workaround now	STORAGE_BACKEND=local. Uploads land on API host disk. No replication, versioning, or AV scan.
Real build	Enable the S3 backend already coded behind ObjectStore. Enable bucket versioning + lifecycle rules matching
Files / modules	app/core/storage/ · app/modules/documents/service.py · infra/s3.tf
Effort	M (S3 wiring + bucket policies: 4 d) · M (AV integration: 3 d)
Acceptance test	1) A file uploaded via the student record is retrievable from any API pod. 2) An EICAR test file is rejected at up

[HIGH] #8. Enterprise 360 computed on every read

Workaround now	Aggregates recompute on read via the replica session. Fast at 266 students; fragile at 5000. Read replica cod
Real build	Add materialised views for the 5 lenses, refreshed by the worker on a schedule (2–5 min). Provision an actual
Files / modules	backend/alembic/versions/xxx_enterprise360_mviews.py (new) · app/modules/reporting/materialised.py · app
Effort	L (mviews + refresh job: 1.5 wk) · S (replica provisioning: 2 d)
Acceptance test	1) Concurrent dashboard load with 5000 seeded students holds p95 < 300 ms. 2) mview refresh completes in

[HIGH] #9. Access-token permission changes take up to 15 min

Workaround now	Access JWTs live 15 min and embed permissions. Role changes only reach a live session after the next refres
Real build	Add a JWT revocation list keyed by jti with hot-revocation check on the auth path. Add POST /admin/users/{id
Files / modules	app/core/security.py · app/modules/identity/service.py · app/modules/identity/routes.py
Effort	M (revocation list + token-version claim: 5 d)
Acceptance test	1) Revoking a role and calling force-signout kicks the target user within 5 s on their next request. 2) The revoc

[HIGH] #10. No deployment artefact, no CI

Workaround now	start-all.bat on a Windows dev machine. Dockerfile in repo but never proven. No CI pipeline running tests.
Real build	Build & publish backend + worker Docker images (already based on python:3.12-slim). Add a compose file for
Files / modules	backend/Dockerfile · frontend/Dockerfile (new) · docker-compose.yml (new) · .github/workflows/ci.yml (new)
Effort	M (Dockerise both apps: 5 d) · M (CI incl. artefact publish: 4 d)
Acceptance test	1) docker compose up brings the full stack up locally. 2) A PR runs the test suite in CI in ≤ 10 min; failure block

[HIGH] #11. Observability: nothing to look at when it breaks

Workaround now	Structured logs with requestId. No traces, no metrics, no error aggregation.
Real build	Add OpenTelemetry to API and worker. Export to whatever the institution uses. Wire the Sentry DSN. Build go
Files / modules	app/core/observability.py (new) · app/main.py (instrument) · app/worker.py (instrument) · infra/dashboards/
Effort	M (OTel + dashboards: 1 wk)
Acceptance test	1) A traced request shows API span → DB span → outbox span across the worker. 2) A synthetic 5xx surface

[HIGH] #12. Older students have broken funding lineage

Workaround now	Pre-Phase-6 students lack research_project rows → funding lineage warns. Funding integrity screen is noisy.
----------------	---

Real build	One-shot backfill script: for each pre-Phase-6 student, either link an existing project or create a stub referencing
Files / modules	backend/scripts/backfill_project_links.py (new) · backend/scripts/README.md
Effort	S (script + review report: 2 d)
Acceptance test	1) After running the script on a prod-copy DB, funding-integrity errors on the cohort drop to zero (or every rem

[HIGH] #13. Ask PGR read-only + Tier-3 policy unresolved

Workaround now	Assistant is read-only. One Tier-3 blocked-action item is unspecified. UI says "I can't change anything."
Real build	Get the Tier-3 policy signed off by the CIO. Ship 5.2 with confirm-before-write per the pattern in PGR_ASSIST
Files / modules	app/modules/assistant/constants.py · app/modules/assistant/tools/ · frontend/src/features/assistant/
Effort	S (policy: 2 d SME time) · L (5.2 writes with confirm: 2 wk)
Acceptance test	1) Signed-off Tier-3 list is committed to constants.BLOCKED_ACTIONS. 2) A write intent produces a preview

Medium-severity work — product debt (S7 onwards)

Compressed to a single table; each row is its own small delivery.

#	Item	Real build	Effort	Acceptance
14	Person merge + contacts + pgr_service.merge(a,b) rewrites FKs; contact model	Two duplicate rows merged by one if user row deleted		
15	Recruitment references + interview_request with token link; interview with panelists	Referenced via token URL; response attached		
16	Conditional offers + fee-status + visa_condition (many per offer) + fee_status + visa_request	Can flag a guarantee international offer without visa flag		
17	Completion classification + ClassificationEnum + governed workflow; certificate PDF	Can platform generate the certificate PDF		
18	Workflow SLA timers	TaskSla with target, elapsed, working-day-aware clock; SLA dashboard		turnaround SLA is reported per week v
19	Integration reconciliation UI (reconciliation) replay; inline assign-person; CSV export	Admin selects 20 dead-letters and replays them in c		
20	Portal actions	Student uploads corrections + supervisor count + sign; supervisor proposals		from portal - enter the cap
21	Cohort + trend reporting + forecast reports	parameterised by intake year; confidence 2022 vs 2023 intake		for progress comparison rende
22	Recruitment route badges - column + chip filter on /recruitment/applications	Filter to Route B and only Route B rows show; badg		
23	Email hygiene	Branded HTML templates, quiet hours, daily digest, list-unsubscribe, bounce handling		the email channel; quiet-h

Policy sign-offs (parallel to engineering)

These are decisions, not code. Chase in parallel with the sprints above; every one blocks a production default becoming a real institutional value.

Decision	Signed off by	Blocks
Supervision capacity + expected interval + part-time factor	PGR Board	Real overdue flags
Correction turnarounds (minor / major)	PGR Board	Real correction clocks
Appeal window days	Regulations owner	Legal defensibility
Retention schedule by data class	Information governance	Gap #5
Login lockout curve (5 / 15 min)	IT security	Gap #3
Tier-3 assistant blocked-action list	CIO	Gap #13
Statutory profile field mappings	Registry / HESA	Gap #6
Integration contracts + HMAC secrets	Programme + partners	Gaps #1, #2

Convergence. When S6 closes, every red row in PGR_Platform_Critical_Gaps.pdf is either shipped or reduced to a controlled amber. From S7 onwards the platform is a normal product-improvement backlog.